Introduction

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Today‘s systems are

- interconnected, e.g. wireless or fixed via IP
- mobile, e.g. smartphone
- heterogeneous, e.g. different wireless technologies

Causes for security issues

- **Bad Design**: missing access control, weak passwords or authentication
- **Implementation Errors**: buffer overflow, weak random number generator
- **Administrative Errors**: missing password, too many open ports (Firewall)
- **Missing Awareness**: poor knowledge, social engineering

[Ecke]

All rights reserved

IT Security Context

Why do we need IT Security?

- Data espionage
- Data manipulation
- Temporary malfunctioning (DoS, DDoS)
- Permanent malfunctioning (Earthquake, Fire, …)
- Attackers who want to know when and who is using the system
- Protection of information and information systems

DoS – Denial of Service
DDoS – Distributed DoS

[Ecke]

All rights reserved

IT Security Context

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Protection against

- External Persons
- Internal users (normal employee)
- Privileged users (Admin, CTO, …)

Attackers

- Inexperienced attacker (Script Kiddies, …)
- Capable Hacker without major budget
- Criminal organization or intelligence agencies

All rights reserved

CTO – Chief Technology Officer [Ecke]

What IT Security is

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Protection of information and information systems against unauthorized access and manipulation as well as ensuring the availability of the services provided by the systems to legitimate users, including all actions to prevent, detect or log threats. Protection against unauthorized access must be constantly ensured, especially during storage, the processing and transmission.

All rights reserved

[Kapp]

IT Security Aims

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Integrity	Protection against unauthorized modification
Confidentiality	Protection against unauthorized access
Availability	Protection against unauthorized impairment of the functionality of components and services
Accountability	No inadmissible denying of performed actions
Authenticity	Proof of the authenticity and credibility of the identity

All rights reserved

[Ecke]

Weakness, Vulnerability and Threat

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Weakness is a weak point in a system which can become vulnerable

Vulnerability is a weakness through which the security services of the system can be circumvented, deceived or modified without authorization

Threat is “a potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm” [Stal2]

Threats utilize one or more weak points or vulnerabilities of a system to endanger one or more security aims

All rights reserved

[Ecke]

Hazard Factors

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

act of nature

lightning strike
fire
flooding
earthquakes
demonstrations
strike

negligence

fallacy
maloperation
inappropriate handling

technical failure

blackout
hardware failure
malfunctions

malice

manipulation
burglary
hacking
vandalism
spying
sabotage

organizational flaws

unauthorized access
pirate copy
untrained staff

All rights reserved

[Ecke]

Risk

- Vulnerabilities are not necessarily discovered and/or exploited
- However, there is a risk
- Risk contains
  - Probability of occurrence
  - Consequences
- Alternatives
  - Leave vulnerability as is
  - Eliminate vulnerability
  - Shutdown the complete IT infrastructure

[Kapp]

All rights reserved

Alternatives

- Choice depends on aims of the decision maker
- If purely economic: Choose alternative with lowest expected mean cost
- Practical problem: Occurrence probabilities and consequences are difficult to guess or estimate

Example:

A webserver is used to collect orders from customers. Security vulnerability discovered in the webserver's software.

1. Immediate fix of vulnerability, cost 10.000 €
2. Free patch from software manufacturer available in 14 days. Expected damage if vulnerability is exploited 60.000 €. Probability of exploit within next 14 days is 0,2 (i.e. 20%).
3. Further alternative: Switch off server temporarily and collect orders via call center. Cost 14.000 €.

[Kapp]

All rights reserved

Example

1. Immediate fix → 10.000 €
2. Wait for patch → 0,2 * 60.000 € + 0,8 * 0 € = 12.000 €
3. Shutdown → 14.000 €

All rights reserved

Which alternative do you choose and why?

[Kapp]

Attacks

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Passive Attacks

- Attacker does not actively participate
- Example: Sniffing, Eavesdropping, Wiretapping
- Difficult to discover
- Preventive means of protection against active attacks

Active Attacks

- Attacker actively manipulates systems or data
- Manipulation of data or systems
- Attacker often leaves traces
- Prevention and detection possible

[Kapp]

All rights reserved

Social Engineering

- Social engineering: targeting attacks not directly on technical systems, but on their User

- Targets are for example:
  - Information gathering (vs. confidentiality)
  - User performs desired actions by the attacker (vs. integrity)

- Use of human characteristics, e.g.:
  - Helpfulness (such as holding a door)
  - Confidence (for example, dealing with people in certain functions)
  - Anxiety (such as threats, physical violence)
  - Respect for authority (e.g., effect of uniforms)
  - Curiosity, laziness, surprise effect, shame, guilt, anger, pride, envy, narcissism, compassion, ...

- Any human weakness can be misused

All rights reserved

[Reis]

Example

Experiment by Thomas Ryan

Robin Sage
N8 at NETWARCOM
Norfolk, Virginia Area

Current	• Cyber Threat Analyst at Naval Network Warfare Command
Past	• Intern at Government Agency
Education	• Massachusetts Institute of Technology • St. Paul's School
Recommended	1 person has recommended Robin
Connections	140 connections
Industry	Computer & Network Security
Websites	• Where I Work • Dark Side of Security • My Facebook

Home About

Tweets 3 | Followers 582 | Likes 59

Robin Sage
@robinsage

Tweets | Tweets & replies | Media

facebook

Robin Sage

About Robin Sage

WORK
Naval Network Warfare Command

EDUCATION
Massachusetts Institute of Technology (MIT)
Cambridge, Massachusetts

Norfolk Highschool

CURRENT CITY AND HOMETOWN
Norfolk, Virginia
Current city

Norfolk, Virginia
Hometown

All rights reserved

Ryan, Thomas (July 2010). "Getting in Bed with Robin Sage" (PDF). Provide Security. Retrieved 25 August 2010.

Social Engineering Categories

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

- Passive Attacks
  - No interaction with victim
  - Eavesdropping on conversations
  - Shoulder surfing (while typing looking over shoulder)
  - Dumpster diving (search in paper barrels)
  - Baiting (leaving prepared USB sticks)

- Active Attacks
  - Pretexting (on the phone as an employee of the IT department)
  - Phishing (get in contact via E-Mail)
  - Internet friendship, e.g. via fake facebook account

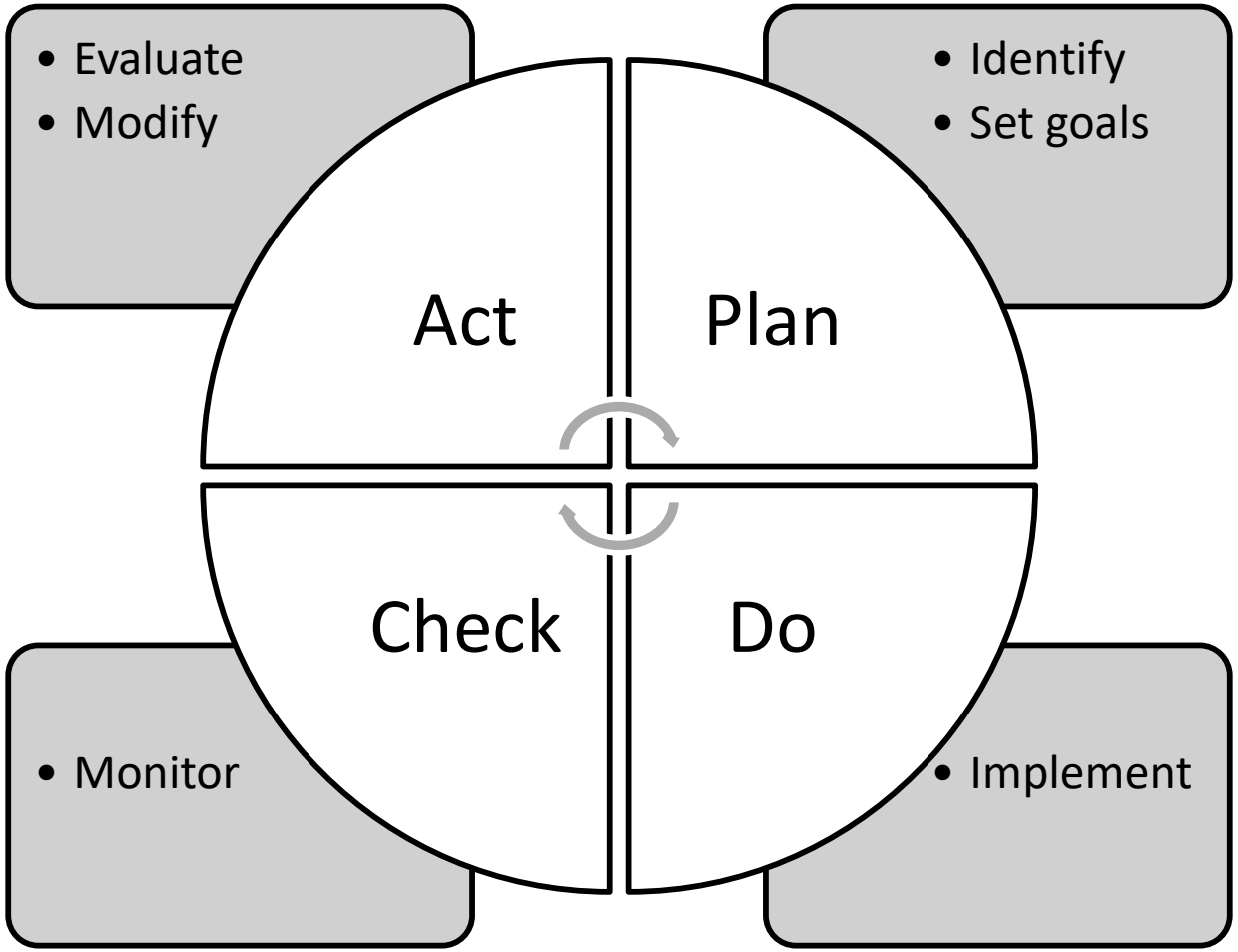
- Mainstream categories
  - Human-based Social Engineering (without technical equipment)
  - Computer-based Social Engineering (with technical equipment)
  - Reverse Social Engineering (victim freely contacts attacker)

[Reis]

All rights reserved

IT Security is a Process

IT Security is a process that is constantly adapted to the state of the art and improved to protect from new attacks.



[Kapp]

All rights reserved

Some Legislative Regulations

FRANKFURT UNIVERSITY OF APPLIED SCIENCES

Relevant Legislative Regulations Concerning IT Security in Germany

- Datenschutzgrundverordnung (General Data Protection Regulation)
  - Regulates collection, processing and use of personal data by public and non-public institutions
- Telekommunikationsgesetz (Telecommunications Act)
  - E.g., secrecy of telecommunications, lawful interception
- Handelsgesetzbuch (German Commercial Code)
  - E.g., trading books must be accessible from data storage devices
- Strafgesetzbuch (Criminal Code)

All rights reserved

[Kapp]